

Security+ 1.4 · Encrypting Data

Mestre CyberSec · Aula 1.4 — Encrypting Data (9:48) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Dado em 3 ESTADOS: AT REST (parado — BitLocker, TDE no banco), IN TRANSIT (viajando — TLS/VPN), IN USE (sendo processado — confidential computing, enclaves CPU). Block cipher (AES — cifra chunks de 128 bits) vs Stream cipher (byte a byte, rápido).

💡 Highlights que a prova CompTIA cobra

- At rest = disco; In transit = rede (TLS); In use = memória (mais difícil)
- AES block cipher cifra em blocos de 128 bits
- Stream cipher: ChaCha20 — bom pra celular, sem hardware AES

🎯 Dicas de Prova & Cenários Típicos da Banca

- Na prova: 'data stored in the database' = at rest; 'during network transfer' = in transit
- Pergunta de 'which provides protection for data in USE' = confidential computing

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Dados em Repouso

Dados armazenados em um meio físico (disco, banco de dados, fita, USB) que não estão em movimento nem sendo processados; protegidos por criptografia de disco completo como BitLocker ou FileVault, ou criptografia no nível do banco como TDE.

⚠ Armadilha CompTIA: Gatilho: 'data stored in the database', 'files on a laptop', 'backup tape' = AT REST. Soluções típicas: BitLocker, FileVault, TDE (Transparent Data Encryption). Não confunda com tráfego de rede.

• Dados em Trânsito

Dados em movimento ativo pela rede entre sistemas; protegidos por criptografia de transporte como TLS/HTTPS, VPN IPsec ou SSH para evitar interceptação e ataques man-in-the-middle.

⚠ Armadilha CompTIA: Gatilho: 'during network transfer', 'data sent over the internet', 'web browser to server' = IN TRANSIT. Protocolos-chave: TLS, HTTPS, IPsec, SSH. Se aparecer 'emails being sent' pense em S/MIME ou TLS de transporte.

• Dados em Uso

Dados sendo processados ativamente na memória ou CPU; o estado mais difícil de proteger porque a criptografia precisa persistir durante o processamento, exigindo confidential computing, enclaves seguros ou ambientes de execução confiáveis na CPU.

⚠ Armadilha CompTIA: Gatilho de prova: 'which provides protection for data IN USE' = CONFIDENTIAL COMPUTING / secure enclave (Intel SGX, AMD SEV, ARM TrustZone). Memória RAM é volátil mas vulnerável — não confunda com at rest.

• Cifra de Bloco

Algoritmo de criptografia que processa os dados em blocos de tamanho fixo (comumente 128 bits) por vez usando chave simétrica; AES é o padrão moderno, com DES e 3DES como exemplos legados.

⚠ Armadilha CompTIA: Gatilho: 'encrypts 128-bit blocks' = BLOCK CIPHER. AES = block cipher de 128 bits (chaves 128/192/256). Precisa de padding se os dados não preencherem o bloco. Diferencie de stream cipher, que cifra byte a byte.

• Cifra de Fluxo

Algoritmo de criptografia que cifra os dados byte a byte (ou bit a bit) combinando o texto claro com um keystream; ChaCha20 e RC4 são exemplos, oferecendo velocidade sem exigir aceleração de hardware AES.

⚠ Armadilha CompTIA: Gatilho: 'good for mobile devices', 'no AES hardware acceleration', 'encrypts one byte at a time' = STREAM CIPHER (ChaCha20). RC4 é stream cipher fraco e depreciado — não use em TLS moderno.

• Computação Confidencial

Modelo de segurança que protege dados em uso realizando a computação dentro de um ambiente de execução confiável baseado em hardware (enclave seguro), de modo que nem o sistema operacional nem o hypervisor possam ler os dados processados.

⚠ Armadilha CompTIA: Se a pergunta for 'protection for data IN USE', a resposta é confidential computing / secure enclave (Intel SGX, AMD SEV, ARM TrustZone). Chave: isolamento em nível de hardware de memória em processamento.

• Criptografia de Dados Transparente (TDE)

Criptografia no nível de banco de dados que cifra os dados em repouso (arquivos de dados, logs, backups) de forma transparente para as aplicações, sem exigir mudanças na aplicação e liberando os dados apenas quando o motor do DB precisa.

⚠ Armadilha CompTIA: Gatilho: 'encrypting database at rest without changing the app' = TDE. É at REST, não in transit. Diferencie de column-level encryption, que é mais granular.

• Segurança da Camada de Transporte (TLS)

Protocolo criptográfico que fornece confidencialidade e integridade para dados em trânsito na rede, usando criptografia simétrica (AES ou ChaCha20) após um handshake assimétrico; sucessor do SSL e base do HTTPS.

⚠ **Armadilha CompTIA:** Gatilho: 'protect data in transit', 'HTTPS', 'secure web traffic' = TLS. Versões modernas: TLS 1.2/1.3. SSL está depreciado. Usa criptografia híbrida: assimétrica no handshake, simétrica nos dados.

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital executa um banco de dados SQL Server que armazena prontuários de pacientes. A conformidade exige que os arquivos do banco e os backups sejam criptografados em repouso sem alterar consultas ou strings de conexão do aplicativo. Qual controle o administrador de segurança deve implementar?

- A) Criptografia Transparente de Dados no banco de dados
- B) TLS 1.3 para todas as conexões de clientes
- C) Enclaves de computação confidencial no servidor de banco de dados
- D) IPsec entre os servidores de aplicação e de banco de dados

QUESTÃO 2 · CENÁRIO DE EXAME

Funcionários remotos usam Wi-Fi público para acessar um CRM em nuvem. A equipe de segurança deve proteger credenciais e dados de sessão enquanto viajam entre o navegador e o serviço em nuvem. Qual controle atende melhor a esse requisito?

- A) Criptografia de disco completo nos notebooks dos funcionários
- B) TLS para o aplicativo web de CRM
- C) Criptografia Transparente de Dados no banco de dados do CRM
- D) Enclaves de computação confidencial na nuvem

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa fornece notebooks a engenheiros que armazenam código-fonte e documentos de projeto localmente. Após vários notebooks serem roubados de veículos, a gerência quer impedir que um invasor que remove o disco leia os dados. Qual solução deve ser implementada?

- A) TLS para todos os aplicativos web internos
- B) Criptografia Transparente de Dados em servidores de arquivos
- C) Criptografia de disco completo nos notebooks
- D) Computação confidencial para cargas de trabalho de desenvolvedores

QUESTÃO 4 · CENÁRIO DE EXAME

Um aplicativo de folha de pagamento é executado em nuvem pública. A equipe jurídica teme que administradores do provedor de nuvem possam inspecionar dados de folha enquanto são processados na memória. Qual tecnologia deve ser usada para proteger os dados em uso?

- A) TLS entre os usuários da folha e a nuvem
- B) Criptografia Transparente de Dados no banco de dados de folha
- C) IPsec entre a rede corporativa e a nuvem
- D) Computação confidencial com ambientes de execução confiáveis baseados em hardware

QUESTÃO 5 · CENÁRIO DE EXAME

Um engenheiro de segurança deve criptografar um fluxo de voz em tempo real, no qual cada byte deve ser protegido imediatamente com mínimo buffering e latência. Qual tipo de cifra é mais adequado para esse requisito?

- A) Cifra de bloco com preenchimento PKCS#7
- B) Cifra de fluxo
- C) Cifra assimétrica como RSA
- D) Função de hash criptográfico

QUESTÃO 6 · CENÁRIO DE EXAME

Um desenvolvedor seleciona AES-256-GCM para criptografar um arquivo de backup de vários terabytes. O documento de projeto deve classificar corretamente o algoritmo criptográfico subjacente. Qual afirmação é precisa?

- A) AES é uma cifra de fluxo porque GCM usa um modo de contador.
- B) AES é uma cifra de bloco simétrica que criptografa blocos de 128 bits, e GCM fornece criptografia autenticada.
- C) AES é uma cifra assimétrica porque usa multiplicação em campo de Galois.
- D) AES é uma função de hash porque GCM produz uma tag de autenticação.

QUESTÃO 7 · CENÁRIO DE EXAME

Um escritório remoto se conecta à matriz pela internet pública usando uma VPN IPsec. O gerente de segurança pergunta qual estado dos dados a VPN protege primariamente para arquivos transferidos entre os sites. Qual é a resposta correta?

- A) Dados em repouso
- B) Dados em trânsito
- C) Dados em uso
- D) Dados nos três estados simultaneamente

QUESTÃO 8 · CENÁRIO DE EXAME

Um invasor rouba fitas de backup criptografadas de um cofre de armazenamento externo. A organização já usa TLS para conexões de banco de dados e enclaves para processamento de dados. Qual controle adicional protege mais diretamente os dados nas fitas roubadas?

- A) Criptografia Transparente de Dados para os backups do banco de dados
- B) TLS 1.3 para administração do servidor de backup
- C) Enclaves de computação confidencial no servidor de backup
- D) Autenticação multifator para administradores de backup

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa financeira deve criptografar tráfego de alto volume entre microserviços. Os servidores incluem aceleração de hardware AES-NI, e o projeto exige confidencialidade e integridade. Qual abordagem criptográfica é mais apropriada?

- A) AES-GCM
- B) RSA-4096
- C) SHA-256
- D) AES-ECB sem autenticação

QUESTÃO 10 · CENÁRIO DE EXAME

Um arquiteto de segurança em nuvem está mapeando controles para proteger dados de clientes nos três estados. Qual mapeamento alinha corretamente um controle a cada estado?

- A)** Criptografia de disco completo para dados em repouso, TLS para dados em trânsito, computação confidencial para dados em uso
- B)** TLS para dados em repouso, criptografia de disco completo para dados em trânsito, TDE para dados em uso
- C)** TDE para dados em uso, IPsec para dados em repouso, enclaves de CPU para dados em trânsito
- D)** Computação confidencial para dados em repouso, TLS para dados em uso, TDE para dados em trânsito

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Criptografia Transparente de Dados no banco de dados

A Criptografia Transparente de Dados (TDE) criptografa arquivos de banco de dados e backups em repouso, mantendo a criptografia transparente para os aplicativos. TLS e IPsec protegem dados em trânsito, e computação confidencial protege dados em uso.

Questão 2: Alternativa B — TLS para o aplicativo web de CRM

O TLS protege dados em trânsito entre o navegador e o serviço em nuvem, criptografando e autenticando o canal de comunicação. Criptografia de disco completo e TDE protegem dados em repouso, enquanto enclaves protegem dados em uso.

Questão 3: Alternativa C — Criptografia de disco completo nos notebooks

A criptografia de disco completo protege dados em repouso em todo o disco do notebook, de modo que remover o disco não expõe dados legíveis. TLS protege dados em trânsito, TDE protege arquivos de banco de dados, e computação confidencial protege dados em uso.

Questão 4: Alternativa D — Computação confidencial com ambientes de execução confiáveis baseados em hardware

A computação confidencial usa ambientes de execução confiáveis, como enclaves de CPU e criptografia de memória, para proteger dados enquanto são processados. TLS e IPsec protegem dados em trânsito, e TDE protege dados em repouso.

Questão 5: Alternativa B — Cifra de fluxo

Uma cifra de fluxo criptografa dados byte a byte e é adequada para fluxos em tempo real que não podem esperar por um bloco completo. Cifras de bloco processam blocos de tamanho fixo e podem adicionar preenchimento; cifras assimétricas e hashes não fornecem criptografia simétrica de fluxo.

Questão 6: Alternativa B — AES é uma cifra de bloco simétrica que criptografa blocos de 128 bits, e GCM fornece criptografia autenticada.

AES é uma cifra de bloco simétrica que processa blocos fixos de 128 bits. GCM é um modo de operação que transforma AES em um modo de criptografia autenticada, mas o algoritmo AES subjacente permanece uma cifra de bloco.

Questão 7: Alternativa B — Dados em trânsito

Uma VPN IPsec criptografa o tráfego enquanto viaja pela internet pública, portanto protege primariamente dados em trânsito. Dados em repouso exigem controles como criptografia de disco completo ou de banco de dados, e dados em uso exigem controles como computação confidencial.

Questão 8: Alternativa A — Criptografia Transparente de Dados para os backups do banco de dados

A Criptografia Transparente de Dados pode criptografar backups de banco de dados em repouso, de modo que fitas roubadas contenham texto cifrado em vez de dados legíveis. TLS, enclaves e MFA não protegem dados em repouso em mídia física.

Questão 9: Alternativa A — AES-GCM

AES-GCM é um modo de criptografia autenticada que fornece confidencialidade e integridade, e se beneficia da aceleração de hardware AES-NI. RSA é assimétrico e mais lento para tráfego em massa, SHA-256 é um hash e não criptografa, e AES-ECB não tem integridade e é inseguro para muitos usos.

Questão 10: Alternativa A — Criptografia de disco completo para dados em repouso, TLS para dados em trânsito, computação confidencial para dados em uso

Criptografia de disco completo e TDE protegem dados em repouso, TLS e IPsec protegem dados em trânsito, e computação confidencial com enclaves de CPU protege dados em uso. Os outros mapeamentos atribuem controles ao estado errado dos dados.